8 Policy languages and frameworks

This chapter covers

- How XACML, OPA/Rego, OpenFGA, and AWS IAM approach authorization in modern, large-scale systems
- Using the PARC framework to analyze various policy languages
- The structure of policies in each language using equivalent policy examples
- Comparisons for choosing the right policy language or framework for your needs

ACME Corp wasn't always a large company. ACME started small, and as it grew, so did the complexity of its authorization needs. What began as a handful of internal systems quickly turned into a sprawling network of cloud infrastructure, customer-facing platforms, and workflows that require strict compliance. Every new system introduced additional requirements, and often, a new approach to policy.

In the early days, ACME's IT team adopted an off-the-shelf document management system that used XACML for access control. The standards-based approach seemed promising, especially for regulated workflows in HR and Finance. However, as the team tried to adapt it to changing business needs, the issues of verbosity, complexity, and tooling became increasingly difficult to ignore.

When ACME's engineering team migrated to Kubernetes and adopted microservices, they faced a different challenge: implementing policies across a decentralized infrastructure. They turned to the Open Policy Agent (OPA) and its Rego language, which provided the flexibility to express complex logic and validate configurations across services. OPA was powerful but not specifically designed for access control, and maintaining reusable, consistent policies was difficult at scale.